

Diarienummer:
DI-2021-2983

Datum:
2021-07-12

Förhandssamråd enligt dataskyddsförordningen avseende drift och support i tredjeland av it- system inom hälso- och sjukvården

Innehåll

Sammanfattande råd.....	2
Bakgrund.....	3
Avgränsning av yttrandet.....	4
Integritetsskyddsmyndighetens yttrande.....	5
Råd 1 Rättsligt stöd för behandlingen.....	6
Regionens redogörelse.....	6
Rättsliga utgångspunkter.....	8
IMY:s bedömning.....	12
Råd 2 Överföring till tredjeland.....	15
Regionens redogörelse.....	15
Rättsliga utgångspunkter.....	16
IMY:s bedömning.....	18
Avslutande medskick.....	20
Riskbedömning av personuppgiftsbiträdet Cerner Sverige AB.....	20
Konsekvensbedömning.....	21
Lights On Network.....	21

Postadress:
Box 8114
104 20 Stockholm

Webbplats:
www.imy.se

E-post:
imy@imy.se

Telefon:
08-657 61 00

Sammanfattande råd

I Integritetsskyddsmyndighetens (IMY) rådgivande roll ingår vid förhandssamråd att ge den personuppgiftsansvarige skriftliga råd om IMY anser att den planerade behandlingen som avses i en konsekvensbedömning skulle strida mot dataskyddsförordningen¹, särskilt om den personuppgiftsansvarige inte i tillräcklig mån har fastställt eller reducerat risken med behandlingen.²

Utifrån den konsekvensbedömning, svar på begäran om komplettering och övrig utredning som Regionstyrelsen Region Skåne (regionen) har gett in lämnar IMY följande råd.

1. IMY råder regionen att inte använda personuppgiftsbiträdena Cerner Healthcare Solutions India Pvt Ltd i Indien och Cerner Corporation och Cerner Health Services Inc. i USA för den tilltänkta personuppgiftsbehandlingen vid drift och support i Indien och USA av it-systemen Millennium och HealthelIntent. Detta eftersom IMY bedömer att det inte finns rättsligt stöd enligt artikel 9.2 h i dataskyddsförordningen för att behandla känsliga personuppgifter hos dessa personuppgiftsbiträden, då kravet på tystnadsplikt i artikel 9.3 i dataskyddsförordningen inte är uppfyllt.

Eftersom det saknas vägledande praxis eller vägledning från Europeiska dataskyddsstyrelsen (EDPB) om tolkningen av artikel 9.3 i dataskyddsförordningen, ger IMY regionen ytterligare råd avseende den planerade överföringen av personuppgifter för drift och support i tredjeland.

2. IMY råder även regionen att utreda tredjelands lagstiftning ytterligare. För det fall regionen efter utredningen kommer fram till att sektion 702 i Foreign Intelligence Surveillance Act (FISA), eller liknande lagstiftning som bedöms gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, blir eller kan tänkas bli tillämplig på överföringen och/eller personuppgiftsbiträdena i USA och Indien, och om behandlingen av personuppgifter kan komma att ske i klartext vid utförandet av drift- och support av it-systemen i dessa länder, bör regionen inte gå vidare med behandlingen.

¹ EUROPAPARLAMENTETS OCH RÅDETS FÖRORDNING (EU) 2016/679 av den 27 april 2016 om skydd för fysiska personer med avseende på behandling av personuppgifter och om det fria flödet av sådana uppgifter och om upphävande av direktiv 95/46/EG (allmän dataskyddsförordning).

² Artikel 35.2 i dataskyddsförordningen.

Bakgrund

Regionen har köpt it-systemen Millennium och HealthelIntent (it-systemen) från bolaget Cerner Sverige AB. Cerner Sverige AB ingår i en koncern med ett amerikanskt moderbolag, Cerner Corporation. Det är tänkt att Cerner Sverige AB kommer anlita underbiträden i Indien via Cerner Healthcare Solutions India Pvt Ltd (Cerner Indien), respektive i USA via Cerner Corporation och Cerner Health Services Inc. (Cerner USA) för utförande av djupare teknisk drift och support av it-systemen. Regionen uppger att de tänker ingå personuppgiftsbiträdesavtal, EU-kommissionens standardavtalsklausuler och sekretessavtal. Regionen har anført att ett antal tekniska, organisatoriska och avtalsmässiga säkerhetsåtgärder kommer vidtas vid behandlingen.

It-systemen är tänkta att utgöra regionens framtida digitala vårdssystem. Millennium beskrivs av regionen som det it-system som stödjer vårdens processer och där journalföring sker. HealthelIntent beskrivs som en plattform med ett antal applikationer och ett centralt datalager där uppgifter om patienter, vårdprocesser och vårdadministration samlas från ett flertal källor, bland annat Millennium. För att möjliggöra en avbrottsfri drift och support är det tänkt att det tillhandahålls genom en global organisation. Syftet med it-systemen är att möjliggöra för regionen att tillhandahålla en god och säker vård till sin befolkning med stöd av modern teknik.

Regionen har genomfört en konsekvensbedömning enligt artikel 35 i dataskyddsförordningen och konstaterat en kvarstående hög risk för enskildas fri- och rättigheter i samband med drift- och support av it-systemen som är tänkt att ske med hjälp av personuppgiftsbiträden i Indien och USA. Regionen har bedömt att den kvarstående höga risken består av att lagstiftningen i Indien respektive USA, om den är tillämplig på personuppgiftsbiträdena, tillåter myndigheter i dessa länder att ta del av uppgifter som personuppgiftsbiträdet kommer ha åtkomst till och på så vis kan komma att leda till obehörig åtkomst av personuppgifter. Regionen bedömer att en eventuell obehörig åtkomst från utländska myndigheter skulle kunna medföra mycket allvarliga konsekvenser för de registrerades fri- och rättigheter såsom ekonomisk, social och fysisk skada. Regionen har vid bedömningen av de registrerades fri- och rättigheter särskilt beaktat att behandlingen omfattar en stor mängd känsliga personuppgifter³ och regionen har även tagit hänsyn till de åsikter som framförts av SDV-projektets⁴ patient- och närståendegrupp. Slutligen har regionen vägt in sannolikheten för obehörig åtkomst och otillåten spridning av personuppgifter och bedömt att sannolikheten för att risken ska inträffa är låg.

Regionen har som underlag för sin bedömning gett in en konsekvensbedömning, ett dokument över informationsflödet vid drift- och supportärenden, ett antal promemorior från olika advokatfirmor, en sammanställning av synpunkter på behandlingen från en patient- och närståendegrupp och utkast till instruktion för behandling av personuppgifter som avser att vara en del av regionens personuppgiftsbiträdesavtal med Cerner Sverige AB och svar på IMY:s begäran om komplettering.

Med anledning av att regionen bedömt att det kvarstår en hög risk för behandlingen har regionen begärt förhandssamråd med IMY enligt artikel 36 i dataskyddsförordningen.

³ I förevarande fall har regionen uppggett att uppgifter om hälsa, biometriska uppgifter, genetiska uppgifter och uppgifter om sexualliv och sexuella läggning kommer behandlas i it-systemen.

⁴ SDV står för Skånes Digitala Vårdssystem.

Avgränsning av yttrandet

IMY:s råd avser endast den personuppgiftsbehandling som regionen bedömt att den är personuppgiftsansvarig för. Yttrandet omfattar därmed inte andra vårdgivare som har vårduppdrag inom det geografiska området för regionen.⁵

Råden avser endast den personuppgiftsbehandling där regionen bedömt att det kvarstår en hög risk⁶, det vill säga den personuppgiftsbehandling som avser den drift- och support av it-systemen som är tänkt att utföras av personuppgiftsbiträden i Indien och USA. Råden omfattar därmed inte personuppgiftsbehandling som är tänkt att genomföras i it-systemen i övrigt.⁷ Råden omfattar inte heller behandling av personuppgifter som sker för drift och support av it-systemen, eller annan personuppgiftsbehandling, som är tänkt att ske hos personuppgiftsbiträdet Cerner Sverige AB.

IMY har i råd 1 bedömt att regionen saknar rättsligt stöd för att behandla känsliga personuppgifter enligt artikel 9.2 h och 9.3 i dataskyddsförordningen hos personuppgiftsbiträdena i Indien och USA. Det saknas därmed anledning för IMY att bedöma om en överföring till tredjeland är möjlig eller inte. Det finns emellertid inte någon vägledande praxis från domstol eller vägledning från EDPB om tolkningen av artikel 9.3 i dataskyddsförordningen. IMY ger därför regionen ytterligare råd avseende den planerade överföringen av personuppgifter för drift och support i tredjeland. Eftersom lagstiftningen och praxis i de aktuella tredjeländerna inte utretts tillräckligt kan IMY inte bedöma om de tilltänkta kompletterande skyddsåtgärderna är tillräckliga. IMY har därför avgränsat råd 2 till att endast gälla behandling av personuppgifter i klartext för drift och support hos personuppgiftsbiträdena i Indien och USA.

Av utredningen framgår att de personuppgifter som regionen avser att överföra till personuppgiftsbiträdena i Indien och USA är sekretessreglerade enligt offentlighets- och sekretesslagen (2009:400), OSL. IMY behandlar emellertid inte frågan om ett utlämnande av personuppgifter till personuppgiftsbiträdena i Indien och USA är förenligt med OSL.

Behandling som eventuellt redan ägt rum inom ramen för it-systemen eller regionens genomförande av SDV-projektet⁸ omfattas inte heller av yttrandet.

Utöver råden ger IMY regionen även några avslutande medskick som regionen kan ta med i sitt fortsatta arbete.

⁵ Jfr 2 kap. 2 § och 15 kap. 1 § hälso- och sjukvårdslagen (2017:30).

⁶ Artikel 36 i dataskyddsförordningen.

⁷ Jfr exempelvis bestämmelser i patientdatalagen (2008:355) eller Socialstyrelsens föreskrifter och allmänna råd om journalföring och behandling av personuppgifter i hälso- och sjukvården (HSFL-FS 2016:40).

⁸ SDV står för Skånes Digitala Vårdsystem.

Integritetsskyddsmyndighetens yttrande

Regionen har anført att de vill tillhandahålla en god och säker vård till sin befolkning genom att ha den driftsäkerhet och funktionalitet som krävs för hälso- och sjukvården och att det i detta bland annat ingår krav på riktighet och tillgänglighet.

IMY konstaterar att krav gällande tillgänglighet framgår uttryckligen av nationella regler som regionen ska följa som personuppgiftsansvarig enligt 2 kap. 6 § patientdatalagen (2008:355), PDL.⁹ IMY har förståelse för det omfattande arbete som regionen har utfört utifrån de underlag som getts in till IMY.

Regionen behöver emellertid följa bestämmelserna i dataskyddsförordningen och andra kompletterande dataskyddsbestämmelser i nationell rätt som gäller för behandlingen, bland annat kravet om rättsligt stöd för behandling av känsliga personuppgifter enligt artikel 9 i dataskyddsförordningen. Regionen har uppgett artikel 9.2 h i dataskyddsförordningen som rättsligt stöd för att få behandla känsliga personuppgifter. Enligt artikel 9.2 h i dataskyddsförordningen krävs bland annat att villkoren om tystnadsplikt i artikel 9.3 i dataskyddsförordningen är uppfyllda.

IMY:s bedömning är att kravet på tystnadsplikt enligt artikel 9.3 i dataskyddsförordningen även omfattar personuppgiftsbiträden. IMY delar inte regionens bedömning om att personuppgiftsbiträdena Cerner Indien och Cerner USA omfattas av en sådan tystnadsplikt som avses i artikel 9.3 i dataskyddsförordningen. IMY gör bedömningen att lagen (2020:914) om tystnadsplikt vid utkontraktering av teknisk bearbetning eller lagring av uppgifter (tystnadspliktslagen) inte medför att kravet om tystnadsplikt i artikel 9.3 är uppfyllt för personuppgiftsbiträden som är verksamma, och behandlar personuppgifter, i Indien och USA.

IMY:s bedömning innebär således att regionen inte har rättsligt stöd i artikel 9.2 h i dataskyddsförordningen för att behandla känsliga personuppgifter hos dessa personuppgiftsbiträden. IMY råder därför regionen att inte använda personuppgiftsbiträdena Cerner Indien och Cerner USA för den tilltänkta personuppgiftsbehandlingen vid drift och support i Indien och USA av it-systemen Millennium och Healthelntent.

Eftersom IMY anser att regionen saknar rättsligt stöd för behandlingen av känsliga personuppgifter hos personuppgiftsbiträdena i Indien och USA konstaterar IMY att det saknas anledning för myndigheten att gå vidare till bedömningen av om en överföring till tredjeland är möjlig eller inte. Det saknas emellertid vägledande praxis från domstol eller vägledning från EDPB om tolkningen av artikel 9.3 i dataskyddsförordningen. IMY ger därför regionen ytterligare ett råd avseende den planerade överföringen av personuppgifter för drift och support i tredjeland.

Vad gäller frågan om överföring av personuppgifter för drift och support till Indien och USA är IMY:s inledande råd att regionen bör utreda tredjelandets lagstiftning ytterligare. För det fall regionen efter ytterligare utredning av tredjelandets lagstiftning kommer fram till att sektion 702 i Foreign Intelligence Surveillance Act (FISA), eller liknande lagstiftning som bedöms gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, blir eller kan tänkas bli tillämplig på överföringen och/eller personuppgiftsbiträdena i Indien och USA, och om tillgång ges till personuppgifter i

⁹ Se 3 kap. HSFL-FS 2016:40.

klartext, dvs. utan exempelvis kryptering eller pseudonymisering¹⁰, råder IMY regionen att inte gå vidare med behandlingen.

Vid bedömningen har IMY särskilt beaktat personuppgifternas mycket integritetskänsliga slag, att antalet registrerade i it-systemen enligt regionens uppskattning uppgår till cirka 1,4 miljoner personer, omfattningen av drift och support som enligt regionens uppgifter är cirka 390 ärenden i månaden där kontakt med personuppgifter kan förekomma och att det ligger i en supporttjänsts natur att supportpersonal behöver få tillgång till personuppgifter i klartext. I bedömningen har IMY även vägt in att det i praktiken inte heller finns något sätt att på förhand göra bedömningar om vilka personuppgifter som kan tänkas förekomma i ett supportärende.

Mot bakgrund av det underlag som regionen kommit in med utvecklar IMY råden enligt följande.

Råd 1 Rättsligt stöd för behandlingen

IMY råder regionen att inte använda personuppgiftsbiträdena Cerner Indien och Cerner USA för den tilltänkta personuppgiftsbehandlingen vid drift och support i Indien och USA av it-systemen Millennium och HealthIntent. Detta eftersom IMY bedömer att det inte finns rättsligt stöd enligt artikel 9.2 h i dataskyddsförordningen för att behandla känsliga personuppgifter hos dessa personuppgiftsbiträden, då kravet på tystnadsplikt i artikel 9.3 i dataskyddsförordningen inte är uppfyllt.

Regionens redogörelse

Region Skåne har en egen intern förvaltningsorganisation för hantering av ärenden inom ramen för Skånes Digitala Vårdsystem. I de fall regionens förvaltningsorganisation inte kan hantera en driftincident, supportärende, utveckling, underhåll eller liknande aktivitet, överförs ärendet till Cerner Sverige AB i Sverige och, i nödvändiga fall, till Cerner Indien och/eller Cerner USA i Indien eller USA. Vilka ärenden som går till Indien respektive USA beror på ärendets art och vilken kompetens som krävs för att lösa ärendet och var första tillgängliga nödvändiga kompetens befinner sig. Vad gäller djupare teknisk support finns merparten av dessa olika kompetensteam i Indien och USA. När det gäller drift och support innebär merparten av uppgifterna inte åtkomst till personuppgifter i ett sammansatt format utan endast åtkomst till information uppdelat i olika databastabeller. När det gäller så kallad applikationssupport är risken för att Cerners supportmedarbetare i tredjeland tar del av personuppgifter mycket större eftersom supportpersonalen då använder sig av applikationen och ser samma informationsmängder som andra användare skulle ha gjort.

Regionen har genom uppgifter från Cerner Sverige AB identifierat att det kan röra sig om cirka 390 ärenden i månaden kopplade till drift- och support av Millennium och HealthIntent som kan överföras till Indien eller USA där risk för kontakt med personuppgifter föreligger. Antal individer som faktiskt överförs i samband med ett ärende där faktisk kontakt med personuppgifter sker är endast i undantagsfall mer än en individ. Vilken data om vilken individ som ett ärende kommer i kontakt med är helt slumpmässigt och kan inte på något sätt förutses. Om ett ärende medför eller riskerar

¹⁰ Jfr European Data Protection Board (EDPB), *Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data*, version 2.0, antagna den 18 juni 2021, s. 34, punkt 94.

att medföra kontakt med personuppgifter eller inte beror på ärendets karaktär och vilka åtgärder som krävs.

Enligt regionen krävs en organisering av supporten som innebär ett snabbt åtagande av varje incident som uppstår så att en effektiv åtgärd kan vidtas och möjliggöra att systemet funktionalitet bibehålls utan avbrott. Om regionen skulle sätta it-systemen i drift utan möjlighet till att vissa personuppgifter överförs till Indien och USA, skulle systemens drift- och supportorganisation inte vara fullständig och därmed skulle regionen ha svårigheter att efterleva kraven i 3 kap. 1 § PDL och 3 kap. 2 och 11 §§ i Socialstyrelsens föreskrifter och allmänna råd om journalföring och behandling av personuppgifter i hälso- och sjukvården (HSLF-FS 2016:40), i synnerhet kraven på riktighet och tillgänglighet i 3 kap. 2 § HSLF-FS 2016:40. Detta mot bakgrund av att Cerner Sverige AB:s nuvarande affärsmodell bygger på en global drift- och supportorganisation. Behandlingen handlar också om att säkerställa att dataskyddsförordningens princip om riktighet efterlevs, jfr artikel 5.1 d i dataskyddsförordningen.

Regionen har för närvarande inte de förutsättningar som krävs och inte heller någon uttalad strategi för att på sikt bygga upp en supportorganisation internt med den mycket specifika kompetens som krävs för att driva it-systemen. På grund av upphovsrättsliga skäl kommer regionen heller inte att kunna bygga upp en helt intern support på sikt. Således är det nödvändigt att support tillhandahålls av Cerner som extern part. Inom ramen för support kan det under vissa förutsättningar ske en överföring av personuppgifter till tredjeland vid de tillfällen personal som är stationerad i Indien eller USA riskerar att ta del av personuppgifter i samband med givandet av support.

De personuppgifter som kan komma att behandlas i it-systemen är personuppgifter kopplade till patienter såsom personnummer, telefonnummer, för- och efternamn, födelsedatum, eventuellt behov av tolk, uppgift om väntelista för olika vårdåtgärder, mätvärden, bokningar, vårdtillfällen, information om vilken vårdcentral personen är listad på, förskrivna läkemedel, uppgifter om hälsa, inklusive genetiska uppgifter, uppgifter om sexuell läggning och sexualliv. Uppgifter till anhöriga kommer också behandlas såsom namn, relation, adress och kontaktuppgifter. I samband med drift och support av journalsystem som används vid vården av patienter, är det ofrånkomligt att de personuppgifter som finns i systemen behandlas. Även användare av it-systemens personuppgifter kommer behandlas såsom namn, unik identifierare, yrkestitel, organisatorisk tillhörighet och kontaktuppgifter. Antalet registrerade personer som kan komma att behandlas i it-systemen uppger regionen är cirka 1,4 miljoner.

Flera av dessa uppgifter utgör särskilda kategorier av personuppgifter enligt dataskyddsförordningen (så kallade känsliga personuppgifter) och sådan behandling är förbjuden enligt artikel 9.1 i dataskyddsförordningen. I artikel 9.2 h anges dock att behandling av känsliga personuppgifter får ske om behandlingen är nödvändig av skäl som hör samman med bland annat förebyggande hälso- och sjukvård och yrkesmedicin, bedömningen av en arbetstagares arbetskapacitet, medicinska diagnoser, tillhandahållande av hälso- och sjukvård, behandling eller av förvaltning av hälso- och sjukvårdstjänster och av deras system, på grundval av unionsrätten eller medlemsstaternas nationella rätt under förutsättning att de villkor och skyddsåtgärder som avses i punkt 3 är uppfyllda. Artikel 9.3 ställer krav på att känsliga personuppgifter behandlas av eller under ansvar av yrkesutövare som omfattas av tystnadsplikt enligt unionsrätten eller medlemsstaternas nationella rätt eller bestämmelser som fastställs

av nationella behöriga organ eller av en annan person som också omfattas av motsvarande reglerad tystnadsplikt.

Regionen anser att underbiträdena, dvs. personuppgiftsbiträdena i Indien respektive USA, omfattas av den tystnadsplikt som sedan den 1 januari 2021 finns för tjänsteleverantörer i lagen om tystnadsplikt vid utkontraktering av teknisk bearbetning eller lagring av uppgifter. Regionen vill även lyfta fram att regeringen i prop. 2017/18:171 *Dataskydd inom Socialdepartementets verksamhetsområde - en anpassning till EU:s dataskyddsförordning* på s. 105, framfört att kravet på lagreglerad tystnadsplikt i artikel 9.3 i dataskyddsförordningen inte omfattar personuppgiftsbiträden.

Rättsliga utgångspunkter

Begreppen personuppgift, uppgift om hälsa, genetiska uppgifter och känsliga personuppgifter

En personuppgift är varje upplysning som avser en identifierad eller identifierbar fysisk person, varvid en identifierbar fysisk person är en person som direkt eller indirekt kan identifieras särskilt med hänvisning till en identifierare som ett namn, ett identifikationsnummer, en lokaliseringssuppgift eller onlineidentifikatorer eller en eller flera faktorer som är specifika för den fysiska personens fysiska, fysiologiska, genetiska, psykiska, ekonomiska, kulturella eller sociala identitet, se artikel 4.1 i dataskyddsförordningen.¹¹

Enligt artikel 4.15 i dataskyddsförordningen definieras uppgift om hälsa som personuppgifter som rör en fysisk persons fysiska eller psykiska hälsa, inbegripet tillhandahållande av hälso- och sjukvårdstjänster, vilka ger information om dennes hälsostatus.¹² Personuppgifter om hälsa bör innefatta alla de uppgifter som hänför sig till en registrerad persons hälsotillstånd som ger information om den registrerades tidigare, nuvarande eller framtida fysiska eller psykiska hälsotillstånd. Detta inbegriper uppgifter om den fysiska personen som insamlats i samband med registrering för eller tillhandahållande av hälso- och sjukvårdstjänster till den fysiska personen enligt Europaparlamentets och rådets direktiv 2011/24/EU, ett nummer, en symbol eller ett kännetecken som den fysiska personen tilldelats för att identifiera denne för hälso- och sjukvårdsändamål, uppgifter som härrör från tester eller undersökning av en kroppsdelen eller kroppssubstans, däribland genetiska uppgifter och biologiska prov, och andra uppgifter om exempelvis sjukdom, funktionshinder, sjukdomsrisk, sjukdomshistoria, klinisk behandling eller den registrerades fysiologiska eller biomedicinska tillstånd, oberoende av källan, exempelvis från en läkare eller från annan sjukvårdspersonal, ett sjukhus, en medicinteknisk produkt eller ett diagnostiskt in vitro-test.¹³

Med genetiska uppgifter avses enligt artikel 4.13 i dataskyddsförordningen alla personuppgifter som rör nedärvda eller förvärvade genetiska kännetecken för en fysisk person, vilka ger unik information om denna fysiska persons fysiologi eller hälsa och vilka framför allt härrör från en analys av ett biologiskt prov från den fysiska personen i fråga.¹⁴

¹¹ Artikel 4.1 dataskyddsförordningen.

¹² Artikel 4.15 i dataskyddsförordningen.

¹³ Skäl 35 i dataskyddsförordningen.

¹⁴ Artikel 4.13 i dataskyddsförordningen.

Med behandling av särskilda kategorier av personuppgifter avses behandling av genetiska uppgifter eller uppgifter om hälsa eller uppgifter om en fysisk persons sexualliv eller sexuella läggning, se artikel 9.1 i dataskyddsförordningen.

Med känsliga personuppgifter avses sådana uppgifter som anges i artikel 9.1 i dataskyddsförordningen, se 3 kap. 5 § lagen (2018:218) med kompletterande bestämmelser i EU:s dataskyddsförordning.

Personuppgiftsansvarig och personuppgiftsbiträde m.m.

Med personuppgiftsansvarig avses, enligt artikel 4.7 i dataskyddsförordningen, en fysisk eller juridisk person, offentlig myndighet, institution eller annat organ som ensamt eller tillsammans med andra bestämmer ändamålen och medlen för behandlingen av personuppgifter. Om ändamålen och medlen för behandlingen bestäms av unionsrätten eller medlemsstaternas nationella rätt kan den personuppgiftsansvarige eller de särskilda kriterierna för hur denna ska utses föreskrivas i unionsrätten eller i medlemsstaternas nationella rätt.

Personuppgiftsansvaret har reglerats i nationell rätt i 2 kap. 6 § PDL för vårdgivare för den behandling av personuppgifter som vårdgivaren utför i samband med individinriktad verksamhet, exempelvis vad gäller skyldigheten att föra patientjournal.

Av artikel 24 i dataskyddsförordningen framgår att den personuppgiftsansvarige ska genomföra lämpliga tekniska och organisatoriska åtgärder för att säkerställa och kunna visa att behandlingen utförs i enlighet med dataskyddsförordningen.

Vidare ska den personuppgiftsansvarige med beaktande av den senaste utvecklingen, genomförandekostnader och behandlingens art, omfattning, sammanhang och ändamål samt riskerna, av varierande sannolikhetsgrad och allvar, för fysiska personers rättigheter och friheter, både vid fastställandet av vilka medel behandlingen utförs med och vid själva behandlingen, genomföra lämpliga tekniska och organisatoriska åtgärder – såsom pseudonymisering – vilka är utformade för ett effektivt genomförande av dataskyddsprinciper – såsom uppgiftsminimering – och för integrering av de nödvändiga skyddsåtgärderna i behandlingen, så att kraven i dataskyddsförordningen uppfylls och den registrerades rättigheter skyddas.¹⁵

Med personuppgiftsbiträde avses, enligt artikel 4.8 i dataskyddsförordningen, en fysisk eller juridisk person, offentlig myndighet, institution eller annat organ som behandlar personuppgifter för den personuppgiftsansvariges räkning.

I artikel 28 i dataskyddsförordningen finns bestämmelser om personuppgiftsbiträden. Av artikel 28.2 framgår att personuppgiftsbiträdet inte får anlita ett annat personuppgiftsbiträde utan att ett särskilt eller allmänt skriftligt förhandstillstånd har erhållits av den personuppgiftsansvarige. Om ett allmänt skriftligt tillstånd har erhållits, ska personuppgiftsbiträdet informera den personuppgiftsansvarige om eventuella planer på att anlita nya personuppgiftsbiträden eller ersätta personuppgiftsbiträden, så att den personuppgiftsansvarige har möjlighet att göra invändningar mot sådana förändringar.

¹⁵ Artikel 25 i dataskyddsförordningen.

När uppgifter behandlas av ett personuppgiftsbiträde ska hanteringen, enligt artikel 28.3 i dataskyddsförordningen, regleras genom ett avtal eller en annan rättsakt enligt unionsrätten eller enligt medlemsstaternas nationella rätt som är bindande för personuppgiftsbiträdet med avseende på den personuppgiftsansvarige och i vilken föremålet för behandlingen, behandlingens varaktighet, art och ändamål, typen av personuppgifter och kategorier av registrerade, samt den personuppgiftsansvariges skyldigheter och rättigheter anges.

I artikel 28.4 anges att i de fall där ett personuppgiftsbiträde anlitar ett annat personuppgiftsbiträde för utförande av specifik behandling på den personuppgiftsansvariges vägnar ska det andra personuppgiftsbiträdet, genom ett avtal eller en annan rättsakt enligt unionsrätten eller enligt medlemsstaternas nationella rätt, åläggas samma skyldigheter i fråga om dataskydd som de som fastställs i avtalet eller den andra rättsakten mellan den personuppgiftsansvarige och personuppgiftsbiträdet enligt artikel 28.3, och framför allt att ge tillräckliga garantier om att genomföra lämpliga tekniska och organisatoriska åtgärder på ett sådant sätt att behandlingen uppfyller kraven i dataskyddsförordningen. Om det andra personuppgiftsbiträdet inte fullgör sina skyldigheter i fråga om dataskydd ska det ursprungliga personuppgiftsbiträdet vara fullt ansvarig gentemot den personuppgiftsansvarige för utförandet av det andra personuppgiftsbiträdets skyldigheter.

Personuppgiftsbiträdet får enligt artikel 29 i dataskyddsförordningen endast behandla personuppgifter på den personuppgiftsansvariges instruktion.

Grundläggande principer, rättslig grund och rättsligt stöd för behandling av känsliga personuppgifter

Personuppgifter ska behandlas enligt de grundläggande principerna i artikel 5.1 i dataskyddsförordningen. Detta innebär bland annat att personuppgifterna ska vara korrekta, om nödvändigt uppdaterade och att de ska behandlas på ett sätt som säkerställer lämplig säkerhet för personuppgifterna, inbegripet skydd mot obehörig eller otillåten behandling och mot förlust, förstöring eller skada genom olyckshändelse, med användning av lämpliga tekniska eller organisatoriska åtgärder.¹⁶

Personuppgiftsansvariga ska enligt artikel 5.2 i dataskyddsförordningen ansvara för, och kunna visa att, principerna i artikel 5.1 efterlevs (principen om ansvarsskyldighet).

För att en behandling av personuppgifter ska vara laglig krävs att den har stöd i någon av de rättsliga grunder som anges i artikel 6.1 i dataskyddsförordningen. Vid behandling av personuppgifter för hälso- och sjukvårdsändamål är det främst artikel 6.1 c (rättslig förpliktelse) eller 6.1 e (allmänt intresse eller myndighetsutövning) som kan vara tillämpliga. Enligt artikel 6.3 ska den grund för behandlingen som anges i artikel 6.1 c och e fastställas i enlighet med unionsrätten eller en medlemsstats nationella rätt som den personuppgiftsansvarige omfattas av. Det innebär att om en vårdgivares behandling av personuppgifter är nödvändig för att fullgöra en rättslig förpliktelse eller utföra en uppgift av allmänt intresse så krävs för att behandlingen ska vara laglig att den rättsliga förpliktelsen eller uppgiften av allmänt intresse regleras i nationell rätt (eller i unionsrätten).

¹⁶ Artikel 5.1 d och f i dataskyddsförordningen.

Hälso- och sjukvårdens uppdrag regleras i bland annat i hälso- och sjukvårdslagen (2017:30), HSL. För verksamhet enligt bland annat HSL finns kompletterande dataskyddsbestämmelser främst i PDL och i HSLF-FS 2016:40, som bland annat innehåller nationella bestämmelser om informationssäkerhet och om fysiskt skydd av informationssystem.

Bestämmelserna i PDL gäller för en vårdgivares behandling av personuppgifter inom hälso- och sjukvården.¹⁷ Enligt 1 kap. 2 § PDL ska informationshantering inom hälso- och sjukvården vara organiserad så att den tillgodoser patientsäkerhet och god kvalitet samt främjar kostnadseffektivitet. Personuppgifter ska utformas och i övrigt behandlas så att patienters och övriga registrerades integritet respekteras. Dokumenterade personuppgifter ska hanteras och förvaras så att obehöriga inte får tillgång till dem.

Behandling av särskilda kategorier av personuppgifter (känsliga personuppgifter), till exempel uppgifter om hälsa och genetiska uppgifter, är enligt artikel 9.1 i dataskyddsförordningen som utgångspunkt förbjuden. I artikel 9.2 regleras en rad undantag från detta förbud. Enligt artikel 9.2 h får känsliga personuppgifter behandlas om behandlingen är nödvändig bland annat av skäl som hör samman med förebyggande hälso- och sjukvård och yrkesmedicin, medicinska diagnoser, tillhandahållande av hälso- och sjukvård, behandling eller förvaltning av hälso- och sjukvårdstjänster, på grundval av unionsrätten eller medlemsstaternas nationella rätt eller enligt avtal med yrkesverksamma på hälsoområdet. För att undantaget i artikel 9.2 h ska vara tillämpligt krävs att villkoren om tystnadsplikt i artikel 9.3 är uppfyllda.

Av artikel 9.3 i dataskyddsförordningen framgår att personuppgifter som avses i artikel 9.1 får behandlas för de ändamål som avses i artikel 9.2 h, när uppgifterna behandlas av eller under ansvar av en yrkesutövare som omfattas av tystnadsplikt enligt unionsrätten eller medlemsstaternas nationella rätt eller bestämmelser som fastställs av nationella behöriga organ eller av en annan person som också omfattas av tystnadsplikt enligt unionsrätten eller medlemsstaternas nationella rätt eller bestämmelser som fastställs av nationella behöriga organ.

Säkerhet i samband med behandling av personuppgifter

Enligt artikel 32.1 i dataskyddsförordningen ska både den personuppgiftsansvarige och personuppgiftsbiträdet vidta lämpliga tekniska och organisatoriska åtgärder för att säkerställa en lämplig säkerhetsnivå till skydd för de uppgifter som behandlas. Vid bedömningen av vilka tekniska och organisatoriska åtgärder som är lämpliga ska den personuppgiftsansvarige och personuppgiftsbiträdet beakta den senaste utvecklingen, genomförandekostnaderna och behandlingens art, omfattning, sammanhang och ändamål samt riskerna för fysiska personers rättigheter och friheter.

Av artikel 32.1 framgår att lämpliga säkerhetsåtgärder kan inbegripa a) pseudonymisering och kryptering av personuppgifter, b) förmågan att fortlöpande säkerställa konfidentialitet, integritet, tillgänglighet och motståndskraft hos behandlingssystemen och tjänsterna, c) förmågan att återställa tillgängligheten och tillgången till personuppgifter i rimlig tid vid en fysisk eller teknisk incident, och d) förfarande för att regelbundet testa, undersöka och utvärdera effektiviteten hos de tekniska och organisatoriska åtgärder som ska säkerställa behandlingens säkerhet.

Vid bedömningen av lämplig säkerhetsnivå ska särskild hänsyn tas till de risker som behandlingen medför, i synnerhet för oavsiktlig eller olaglig förstöring, förlust eller

¹⁷ 1 kap. 1 § PDL.

ändring eller till obehörigt röjande av eller obehörig åtkomst till de personuppgifter som överförts, lagrats eller på annat sätt behandlats.¹⁸

IMY:s bedömning

Utifrån vad regionen redogjort för konstaterar IMY att personuppgiftsbiträdena Cerner Indien respektive Cerner USA vid utförande av support kan komma att ta del av både personuppgifter och känsliga personuppgifter för att utföra sina tjänster. Som regionen anfört är det svårt att i förväg förutse vilka personuppgifter som en medarbetare hos personuppgiftsbiträdena kan komma att ta del av vid varje ärende.

För att regionen ska uppfylla sitt uppdrag i egenskap av vårdgivare krävs, utöver att regionen följer dataskyddsförordningen, att regionens it-system uppfyller kraven i nationella regler såsom PDL och HSLF-FS 2016:40.

Behandling av personuppgifter för drift och support i it-system som är nödvändig för att regionen ska kunna utföra sitt författningsreglerade uppdrag inom vården har enligt IMY:s bedömning rättslig grund enligt artikel 6.1 i dataskyddsförordningen.

Som konstateras ovan omfattar den aktuella behandlingen känsliga personuppgifter. För att behandling av sådana uppgifter ska vara tillåten krävs att något av undantagen i artikel 9 i dataskyddsförordningen är tillämpligt. Regionen har angett att undantaget i artikel 9.2 h utgör stöd för behandlingen av känsliga personuppgifter, vilket kräver att villkoren om tystnadsplikt i artikel 9.3 i dataskyddsförordningen är uppfyllda.

Av artikel 9.3 i dataskyddsförordningen framgår att personuppgifter som avses i artikel 9.1 får behandlas för de ändamål som avses i artikel 9.2 h, när uppgifterna behandlas av eller under ansvar av en yrkesutövare som omfattas av tystnadsplikt enligt unionsrätten eller medlemsstaternas nationella rätt eller bestämmelser som fastställs av nationella behöriga organ eller av en annan person som också omfattas av tystnadsplikt enligt unionsrätten eller medlemsstaternas nationella rätt eller bestämmelser som fastställs av nationella behöriga organ.

Bestämmelsen ställer således krav på att det ska finnas en tystnadsplikt som antingen är (i) reglerad i unionsrätten eller medlemsstaternas nationella rätt eller (ii) fastställs av nationella behöriga organ. När det gäller frågan vilka aktörer som måste omfattas av tystnadsplikten finns det ett visst utrymme för olika tolkningar. Regeringen har i ett lagstiftningsärende gjort bedömningen att kravet på en reglerad yrkesmässig tystnadsplikt i artikel 9.3 i dataskyddsförordningen inte omfattar personuppgiftsbiträden.¹⁹ Bedömningen gjordes bland annat mot bakgrund av dataskyddsförordningens krav på att ett personuppgiftsbiträdes hantering av personuppgifter ska regleras i ett avtal som särskilt ska föreskriva att personuppgiftsbiträdet säkerställer att personer med behörighet att behandla personuppgifterna har åtagit sig att iaktta konfidentialitet eller omfattas av en lämplig (lagstadgad) tystnadsplikt.

IMY har emellertid i flera lagstiftningsärenden uttryckt att personuppgiftsbiträden som agerar inom hälso- och sjukvården omfattas av kravet på tystnadsplikt i bestämmelsen

¹⁸ Artikel 32.2 i dataskyddsförordningen.

¹⁹ Prop. 2017/18:171 s. 105.

och att tystnadsplikten i artikel 9.3 i dataskyddsförordningen behöver utredas ytterligare.²⁰

Det kan konstateras att artikel 9.3 inte innehåller någon uttrycklig begränsning av kravet på tystnadsplikt till behandling hos den personuppgiftsansvarige. Bestämmelsens ordalydelse talar således för att den även riktar sig till personuppgiftsbiträden. Enligt IMY ligger det också närmast till hands att tolka begreppen "yrkesutövare" och "annan person" som att de begreppen avser fysiska personer. Det innebär att den möjlighet att låta en person utan tystnadsplikt behandla känsliga personuppgifter förutsätter att det finns en yrkesutövare som omfattas av tystnadsplikt, till exempel en läkare eller sjuksköterska, som ansvarar för den faktiska behandlingen.

Enligt IMY talar även ändamålsskäl för tolkningen att artikel 9.3 omfattar personuppgiftsbiträden. När känsliga personuppgifter behandlas med stöd av undantaget i artikel 9.2 h är tystnadsplikt enligt artikel 9.3 den enda skyddsåtgärd som krävs. En begränsning av skyddsåtgärdens omfattning till att endast omfatta personer hos den personuppgiftsansvarige skulle innebära en försämring av det integritetsskydd som skyddsåtgärden syftar till att upprätthålla. Enligt IMY:s uppfattning kan inte en avtalsreglerad tystnadsplikt – som enligt artikel 28.3 b i dataskyddsförordningen räcker för personal hos ett personuppgiftsbiträde – jämföras med det krav på lagstadgad eller liknande tystnadsplikt som gäller enligt artikel 9.3. IMY:s slutsats är således att artikel 9.3 inte bara omfattar behandling hos personuppgiftsansvariga utan även behandling som utförs av personuppgiftsbiträden.

Vad gäller kravet på tystnadsplikt för det allmännas verksamhet inom hälso- och sjukvård i Sverige gäller OSL.²¹ I förevarande ärende innebär det att regionens personal inom hälso- och sjukvård omfattas av en lagstadgad tystnadsplikt enligt OSL som dessutom är straffsanktionerad.²² Villkoret gällande lagstadgad tystnadsplikt i artikel 9.3 i dataskyddsförordningen får därmed anses uppfyllt för regionens egen personal.

Däremot omfattas inte personal hos de personuppgiftsbiträden som regionen anlitar av tystnadsplikt enligt OSL, se 2 kap. 1 § andra stycket OSL och JO:s beslut från den 9 september 2014, dnr 3032-2011 och JO:s beslut från den 4 juni 2019, dnr 6794-2017 och dnr 6864-2017.

Från och med den 1 januari 2021 gäller tystnadspliktslagen när en myndighet uppdrar åt ett företag eller en annan enskild (tjänsteleverantör) att endast tekniskt bearbeta eller tekniskt lagra uppgifter.²³ I förarbetena till lagen uttalas att vilka åtgärder som kan omfattas av begreppet "teknisk bearbetning eller teknisk lagring" behöver tolkas i förhållande till dagens digitala informationshantering och den fortgående tekniska utvecklingen. Åtgärder det kan handla om är förändring och tillägg i en befintlig tjänsts funktionalitet, etablering av en tilläggstjänst, integration mot andra tjänster, konfiguration, test och utveckling och tillhandahållande av supporttjänster. Det kan också röra sig om säkerhetshöjande åtgärder som uppgradering, uppdatering,

²⁰ Datainspektionens yttrande dnr 904-2017 från den 22 juni 2017, Datainspektionens yttrande dnr 1210-2017 från den 4 september 2017, Datainspektionens yttrande dnr 1954-2017 från den 1 november 2017 och Datainspektionens yttrande dnr DI-2018-7602 från den 4 oktober 2018. Yttrandena finns tillgängliga på IMY:s webbplats.

²¹ Jfr 1 kap. 1 § OSL och 25 kap. 1 § OSL. För privata aktörer inom hälso- och sjukvården gäller bestämmelserna i 6 kap. 12-16 §§ patientsäkerhetslagen (2010:659).

²² Jfr 20 kap. 3 § brottsbalken.

²³ 1 § tystnadspliktslagen.

säkerhetskopiering, kryptering, anonymisering, pseudonymisering och incidenthantering.²⁴

IMY kan konstatera att ett personuppgiftsbiträde som endast tekniskt bearbetar eller tekniskt lagrar uppgifter, såsom exempelvis drift och support av ett it-system åt en myndighet, kan omfattas av tystnadspliktslagen. Av 4 § i lagen framgår att den som på grund av anställning eller på något annat sätt deltar i eller har deltagit i en tjänsteleverantörs verksamhet att på uppdrag av en myndighet endast tekniskt bearbeta eller tekniskt lagra uppgifter inte obehörigen får röja eller utnyttja dessa uppgifter. Av 3 § i samma lag framgår att med en tjänsteleverantör ska jämföras en underleverantör som medverkar till att fullgöra tjänsteleverantörens uppdrag. Tystnadsplikten enligt tystnadspliktslagen är straffsanktionerad enligt 20 kap. 1 § brottsbalken.

IMY anser emellertid att det råder osäkerhet om tystnadspliktslagens räckvidd vad gäller personuppgiftsbiträden utanför Sveriges gränser. Det kan konstateras att tystnadspliktslagen inte innehåller någon uttrycklig reglering om lagens territoriella tillämpningsområde.

I förarbetena till tystnadspliktslagen anger regeringen att det inte är ovanligt att en tjänsteleverantör, eller en underleverantör som är anlitad av tjänsteleverantören, är etablerad eller bedriver sin verksamhet utanför Sveriges gränser. Regeringen anför även att var en uppgiftshantering sker rent geografiskt kan påverka lagens räckvidd, men att den nya lagen inte ska påverka befintliga möjligheter att anlita en tjänsteleverantör som är etablerad eller driver sin verksamhet utanför Sveriges gränser. Det gäller enligt regeringen även när tjänsteleverantören agerar i rollen som personuppgiftsbiträde enligt dataskyddsförordningen. Någon risk för konflikt mellan regleringen i den allmänna dataskyddsförordningen och lagen uppkommer därmed inte enligt regeringen.²⁵

I förarbetena uttalas vidare följande. Frågan om huruvida ett brott mot tystnadsplikt som begås utanför Sveriges gränser kan bedömas av svensk domstol avgörs utifrån den generella regleringen av tillämpligheten av svensk lag i 2 kap. brottsbalken. Det innebär normalt, för sådana brott mot tystnadsplikten som begås utomlands, att svensk domsrätt kommer att finnas om brottet begås av en svensk medborgare eller av en utlänning med hemvist i Sverige, se 2 kap. 2 § första stycket 1 brottsbalken. Som ett ytterligare krav gäller att gärningen ska vara straffbar även på gärningsorten, så kallad dubbel straffbarhet. Enligt 2 kap. 3 § första stycket 4 brottsbalken är svensk domstol behörig att döma över ett brott som har begåtts utomlands trots att det inte föreligger dubbel straffbarhet, om brottet har förövats mot Sverige, svensk kommun eller annan menighet eller en svensk allmän inrättning. Regeringen framför att det kan finnas många situationer där det kan sättas i fråga om ett röjande av uppgifter är att anse som ett brott riktat mot svenska intressen, exempelvis röjande av enstaka namn eller adressuppgifter. Vidare anför regeringen att det därför är viktigt att fortsatt reglera tystnadsplikt i avtal för de fall där brott mot tystnadsplikten i den nya lagen inte kan beivras.²⁶

Enligt IMY:s uppfattning går det inte utifrån dessa förarbetsuttalanden att dra någon bestämd slutsats när det gäller i vilken utsträckning tystnadspliktslagen är avsedd att vara tillämplig i utlandet. Det framgår dock att möjligheten att utöva svensk domsrätt

²⁴ Prop. 2019/20:201 s. 22.

²⁵ Prop. 2019/20:201 s. 13.

²⁶ Prop. 2019/20:201 s. 20.

vid överträdelser av tystnadsplikten utomlands är mycket begränsade. IMY kan utifrån utredningen i ärendet inte heller dra någon slutsats om att det skulle finnas särskilda förutsättningar för detta i Indien eller USA.

Mot bakgrund av vad som anförs ovan gör IMY bedömningen att regionen inte uppfyller kravet i artikel 9.3 i dataskyddsförordningen om tystnadsplikt för personuppgiftsbehandling som sker hos personuppgiftsbiträden i Indien och USA. IMY:s bedömning innebär att regionen inte har rättsligt stöd i artikel 9.2 h i dataskyddsförordningen för att behandla känsliga personuppgifter hos dessa personuppgiftsbiträden.

IMY anser även att det är ett flertal omständigheter för den tilltänkta behandlingen avseende drift och support hos personuppgiftsbiträdena i tredjeland som manar till särskild försiktighet, dessa är:

- att personuppgifterna som är tänkta att behandlas är av mycket integritetskänslig karaktär och i stor utsträckning utgör känsliga personuppgifter,
- att personuppgiftsbehandlingen kan komma att omfatta alla invånare i regionens geografiska område, vilket regionen uppskattar till cirka 1,4 miljoner registrerade personer och
- den förhållandevis stora omfattningen av drift- och supportärenden där personuppgifter kan komma att behandlas (enligt regionens uppgift cirka 390 ärenden i månaden till Indien eller USA).

Sammantaget gör dessa omständigheter att IMY råder regionen att inte använda sig av personuppgiftsbiträdena Cerner Indien och Cerner USA för behandlingen av känsliga personuppgifter för drift och support av it-systemen.

Råd 2 Överföring till tredjeland

IMY råder även regionen att utreda tredjelands lagstiftning ytterligare. För det fall regionen efter utredningen kommer fram till att sektion 702 i Foreign Intelligence Surveillance Act (FISA), eller liknande lagstiftning som bedöms gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, blir eller kan tänkas bli tillämplig på överföringen och/eller personuppgiftsbiträdena i USA och Indien, och om behandlingen av personuppgifter kan komma att ske i klartext vid utförandet av drift- och support av it-systemen i dessa länder, bör regionen inte gå vidare med behandlingen.

Regionens redogörelse

Regionen har lämnat in två promemorior från advokatfirmor som regionen anlitat för att utreda bland annat lagstiftningen i Indien respektive USA. Advokatfirmorna har i sin tur vänt sig till en advokatfirma i USA gällande amerikansk rätt och en advokatfirma i Indien gällande indisk rätt. Regionen har också lämnat in promemorior från en svensk advokatfirma som Cerner Sverige AB har anlitat. Den advokatfirman har också vänt sig till en advokatfirma i USA och till en advokatfirma i Indien för att utreda tredjelands lagstiftning.

I konsekvensbedömningen anför regionen att underlaget från advokatfirmorna visar att det finns lagstiftning i Indien och USA som kan ge ländernas myndigheter rätt att ta del av uppgifter hos underbiträden i respektive land. Regionen anför att utredningarna också visar att det finns lagstiftning som inte är densamma som inom EU/EES.

Att USA inte kan garantera registrerade en tillräcklig nivå av skydd för sina fri- och rättigheter har enligt regionen slagits fast i EU-domstolens dom i mål C-311/18 (Schrems II-domen). Eftersom lagstiftningen i varken Indien eller USA utgör ett tillräcklig skydd för de registrerades rättigheter, planerar regionen att vidta lämpliga skyddsåtgärder enligt artikel 46 i dataskyddsförordningen genom att ingå EU-kommissionens standardavtalsklausuler med personuppgiftsbiträdet och relevanta underbiträden. Regionen har även tänkt att vidta både tekniska, organisatoriska och avtalsmässiga kompletterande åtgärder vilka också beskrivs i underlaget.

Regionen framför samtidigt i sitt svar med komplettering till IMY att det inte är klarlagt huruvida Cerner USA omfattas av övervakningsprogram som sker med stöd av 702 FISA och att det inte heller är klarlagt huruvida den indiska lagstiftningen Section 69 IT Act överhuvudtaget blir tillämplig på Cerner Indien eftersom advokatfirmorna kommit fram till olika slutsatser gällande det.

Regionen anför i kompletteringen att dess samlade bedömning är att sannolikheten eller risken för att indiska eller amerikanska myndigheter begär och får tillgång till personuppgifter som överförs till Cerner Indien och Cerner USA är låg. Regionen anser därmed att det är låg sannolikhet för att risken överhuvudtaget inträffar och anför även att det borde vara möjligt att beakta risken för att myndigheterna i Indien respektive USA i praktiken begär och får åtkomst till de personuppgifter som överförs i samband med drift och support.

Rättsliga utgångspunkter

Som anges ovan behöver den personuppgiftsansvarige som ett första steg säkerställa att det finns en rättslig grund för behandlingen enligt artikel 6 i dataskyddsförordningen, att de grundläggande principerna i artikel 5 i dataskyddsförordningen är uppfyllda och att övriga krav i dataskyddsförordningen är uppfyllda såsom exempelvis villkoren för behandling av känsliga personuppgifter i artikel 9 och kraven på säkerhet i samband med behandlingen enligt artikel 32 i dataskyddsförordningen. Om samtliga krav är uppfyllda enligt dataskyddsförordningen kan en överföring till exempelvis ett personuppgiftsbiträde i tredjeland ske om villkoren i kapitel V i dataskyddsförordningen är uppfyllda. Enligt kapitel V kan överföring ske bland annat om lämpliga skyddsåtgärder vidtas enligt artikel 46 i dataskyddsförordningen. En lämplig skyddsåtgärd kan enligt artikel 46.2 c vara att EU-kommissionens standardavtalsklausuler används.

I de fall mottagarlandet inte uppnår en i allt väsentligt likvärdig skyddsnivå för uppgifterna som inom EU eller EES, till exempel eftersom lagstiftningen i mottagarlandet innebär att skyddet som tillhandahålls genom överföringsverktyget inte kan upprätthållas i praktiken, kan de lämpliga skyddsåtgärderna, såsom EU-kommissionens standardavtalsklausuler, behöva kompletteras med ytterligare skyddsåtgärder.

Av EU-domstolens dom i mål C-311/18 (Schrems II-domen) framgår att det ankommer på den personuppgiftsansvarige eller personuppgiftsbiträdet att i varje enskilt fall och i samarbete med mottagaren av överföringen, kontrollera huruvida lagstiftningen i mottagarlandet säkerställer ett lämpligt skydd med hänsyn till unionsrätten för personuppgifter som överförs med stöd av standardavtalsklausuler och att vid behov tillhandahålla ytterligare skyddsåtgärder utöver dem som erbjuds genom standardavtalsklausulerna.²⁷ Domstolen anförde att även om det finns situationer där mottagaren, beroende på rättsläget och gällande praxis i det berörda tredjelandet, kan

²⁷ Dom Schrems II, C-311/18, EU:C:2020:559, punkt 134.

garantera det nödvändiga skyddet av uppgifter enbart med stöd av standardavtalsklausulerna, finns det andra situationer i vilka bestämmelserna i dessa klausuler inte kan vara ett tillräckligt medel för att i praktiken säkerställa ett effektivt skydd av de personuppgifter som överförs till det berörda tredjelandet. EU-domstolen anförde att det bland annat är så när lagstiftningen i det tredjelandet tillåter att myndigheterna i detta tredjeland gör ingrepp i de registrerade personernas rättigheter avseende dessa uppgifter.²⁸

EU-domstolen anförde även att eftersom standardavtalsklausulerna inte kan leda till skyddsåtgärder som går utöver en avtalsenlig skyldighet att säkerställa att den skyddsnivå som krävs enligt unionsrätten iakttas, kan det vara nödvändigt, beroende på den situation som råder i ett visst tredjeland, för den personuppgiftsansvarige att vidta ytterligare åtgärder för att säkerställa att skyddsnivån iakttas.²⁹

Till hjälp för att avgöra om ett land ska anses ha en tillräcklig skyddsnivå har EDPB, där IMY ingår, tagit fram rekommendationer³⁰ där det anges vilka grundläggande garantier som måste respekteras när ett land beslutar om ingrepp i rätten till integritets- och dataskydd (exempelvis genom övervakningsåtgärder), för att dessa ingrepp inte ska gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle.

I Schrems II-domen konstaterade EU-domstolen att varken sektion 702 i FISA, Executive Order 12333, jämförda med Presidential Policy Directive 28 (PPD-28), motsvarar de minimikrav som gäller i unionsrätten enligt proportionalitetsprincipen, varför det enligt EU-domstolens mening inte kan anses att de övervakningsprogram som grundar sig på dessa bestämmelser är begränsade till vad som är strikt nödvändigt, vilket innebär att skyddsnivån inte är väsentligen likvärdig med det skydd som garanteras inom EU/EES.³¹

Efter Schrems II-domen har EDPB även tagit fram rekommendationer gällande vilka ytterligare skyddsåtgärder som kan användas vid överföring av personuppgifter till länder utanför EU eller EES när skyddsnivån i mottagarlandet inte kan anses tillförsäkra en likvärdig skyddsnivå som inom EU eller EES. Dessa rekommendationer³² antogs slutligt den 18 juni 2021. Rekommendationerna innehåller ett antal steg som den aktör som vill överföra personuppgifter till tredjeland rekommenderas att följa.

Efter att den som ska överföra personuppgifter har identifierat vilka överföringar som är tänkta att genomföras och vilket överföringsverktyg i kapitel V i dataskyddsförordningen som kommer användas, är nästa steg vid användning av något av överföringsverktygen i artikel 46 i dataskyddsförordningen, att utreda huruvida verktyget är effektivt i praktiken mot bakgrund av omständigheterna för överföringen. I det ingår att bedöma själva överföringen och vilken lagstiftning och/eller praxis i det aktuella tredjelandet som blir, eller kan tänkas bli, tillämplig på överföringen och/eller mottagaren av personuppgifterna.³³ Här ingår det även att göra en

²⁸ Anförd dom, punkt 126.

²⁹ Anförd dom, punkt 133.

³⁰ European Data Protection Board (EDPB), *Recommendations 02/2020 on the European Essential Guarantees for surveillance measures*, antagna den 10 november 2020.

³¹ Dom Schrems II, EU-domstolens dom, C-311/18, EU:C:2020:559, punkt 184.

³² European Data Protection Board (EDPB), *Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data*, version 2.0, slutligt antagna efter publik konsultation.

³³ Jfr artikel 5.2 i dataskyddsförordningen och EDPB:s rekommendationer 01/2020, s. 19, punkt 48.

bedömning av det grundläggande rättighetsskyddet.³⁴ Exempel på källor som kan användas för att utreda tredjelandets lagstiftning och/eller praxis återfinns i bilaga 3 i EDPB:s rekommendationer.

Rekommendationerna betonar vikten av att undersöka den praktiska tillämpningen hos offentliga myndigheter i det aktuella tredjelandet för att kunna avgöra om lagstiftningen och/eller praxis i tredjelandet i praktiken påverkar effektiviteten av de lämpliga skyddsåtgärder som vidtagits enligt artikel 46 i dataskyddsförordningen. Om en aktör som vill överföra personuppgifter till ett tredjeland identifierat att det finns problematisk lagstiftning³⁵ som är tillämplig på aktören och/eller behandlingen i praktiken, ska denne avbryta överföringen eller vidta ytterligare skyddsåtgärder för att kunna genomföra överföringen.³⁶

Det är den som vill överföra personuppgifter som har ansvar att utreda och dokumentera vilken lagstiftning och/eller praxis som är tillämplig för överföringen eller personuppgiftsbiträden i tredjeland.³⁷

Om den som vill överföra uppgifter gjort bedömningen att skyddet som tillhandahålls genom överföringsverktyget inte kan upprätthållas i praktiken och det därför behöver införas kompletterande skyddsåtgärder ska en bedömning göras av vilka skyddsåtgärder som behöver vidtas för att en väsentligt likvärdig skyddsnivå ska uppnås. Det är en **helhetsbedömning** som behöver göras i varje enskilt fall. Bilaga 2 i EDPB:s rekommendationer innehåller en icke uttömmande lista med exempel på sådana ytterligare skyddsåtgärder.

Vad gäller möjligheten för ett personuppgiftsbiträde som behöver ta del av personuppgifter i klartext för att kunna utföra sitt arbete i ett tredjeland där offentliga myndigheter i mottagarlandet har laglig möjlighet att komma åt de överförda uppgifterna som går längre än vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, kan EDPB utifrån den senaste tekniska utvecklingen inte se att det finns några effektiva tekniska åtgärder som skulle förhindra att åtkomsten inkräktar på de registrerades grundläggande rättigheter.³⁸

Samma sak anser EDPB gäller när personuppgifter överförs för affärsändamål som inkluderar fjärråtkomst till personuppgifter i klartext i länder vars lagstiftning möjliggör för offentliga myndigheter i mottagarlandet att komma åt de överförda uppgifterna som går utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle.³⁹

Vidare anför EDPB att det i situationer där okrypterade personuppgifter är nödvändiga för att personuppgiftsbiträdet ska kunna genomföra tjänsten, är kryptering vid transport och data i vila-kryptering, och även om dessa åtgärder vidtas tillsammans, inte att anse som kompletterande skyddsåtgärder som säkerställer en väsentligt likvärdig skyddsnivå om aktören som mottar personuppgifter har krypteringsnyckeln.⁴⁰

IMY:s bedömning

IMY konstaterar inledningsvis, utifrån det underlag som regionen presenterat gällande tillämplig lagstiftning i Indien och USA, att regionen inte i tillräcklig omfattning utrett

³⁴ Jfr Dom Schrems II, C-311/18, EU:C:2020:559, punkt 105.

³⁵ När det gäller begreppet "problematisering", se EDPB:s rekommendationer 01/2020, s. 17, fotnot 50.

³⁶ EDPB:s rekommendationer 01/2020, s. 17 ff., punkterna 43.3 och 49.

³⁷ Jfr artikel 5.2 i dataskyddsförordningen och EDPB:s rekommendationer 01/2020, s. 19, punkt 48.

³⁸ EDPB:s rekommendationer 01/2020, s. 35, punkt 94, bilaga 2.

³⁹ EDPB:s rekommendationer 01/2020, s. 35, punkt 96, bilaga 2.

⁴⁰ EDPB:s rekommendationer 01/2020, s. 35, punkterna 95 och 97, bilaga 2.

vilken lagstiftning och/eller praxis som gäller eller kan komma att gälla för överföringen och/eller personuppgiftsbiträdena i Indien respektive USA. Det framgår inte heller att regionen har undersökt de offentliga myndigheternas praktiska tillämpning i de aktuella länderna eller att regionen varit i kontakt med andra aktörer inom samma sektor för att utreda vilken lagstiftning och praxis som kan bli aktuell. Källorna och informationen som regionen förlitar sig på ska vara relevanta, objektiva, tillförlitliga, verifierbara och allmänt tillgängliga.⁴¹ Se mer om det i EDPB:s rekommendationer punkterna 44-47 och bilaga 3 till rekommendationerna.

IMY råder därför regionen att utreda tredjelands lagstiftning för Indien och USA mer utförligt.

För det fall regionen efter utredningen kommer fram till att sektion 702 i FISA, eller liknande lagstiftning som bedöms gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, skulle vara tillämplig på överföringen eller personuppgiftsbiträdena i Indien och USA, och behandling av personuppgifter är tänkt att ske i klartext vid utförandet av drift- och support av it-systemen i dessa länder, är IMY:s råd att regionen inte bör genomföra behandlingen.

I denna del har IMY framför allt beaktat följande.

IMY har uppfattat det som att de aktuella it-systemen kan komma att behandla personuppgifter om hela regionens befolkning, vilket regionen uppskattar är cirka 1,4 miljoner registrerade personer. Det rör sig således om en omfattande behandling av mycket integritetskänsliga personuppgifter om patienter såsom uppgifter om hälsa, biometrisk data, genetiska uppgifter och uppgifter om sexualliv och sexuell läggning. Även närståendes personuppgifter och personuppgifter för användare av it-systemen kommer att behandlas i stor omfattning. Uppgifter inom hälso- och sjukvård omfattas dessutom av stark sekretess enligt OSL. Om personuppgifterna skulle lämnas ut till utländska myndigheter skulle det därmed enligt IMY:s uppfattning kunna leda till mycket allvarliga konsekvenser för registrerades fri- och rättigheter.

Det är också fråga om behandling av uppgifter i klartext. Regionen erhåller support av Cerner Indien och Cerner USA för drift-, underhåll- och applikationssupport. Regionen uppger att kontakt med personuppgifter i klartext anses vara mycket större för supportmedarbetare i tredjeland vid utförande av applikationssupport eftersom det kräver att supportmedarbetaren ser samma information som andra användare. Vidare uppger regionen att det kommer vara helt slumpmässigt vilket ärende som kommer innebära behandling av personuppgifter och att det inte på något sätt kan förutses.

Enligt IMY:s uppfattning får det normalt sett anses ligga i en supporttjänsts natur att supportpersonal kan behöva ta del av personuppgifter i klartext för att kunna utföra vissa arbetsuppgifter. Det kan gälla både vid drift-, underhålls- och applikationssupport. Även om regionen har vidtagit olika tekniska skyddsåtgärder för att supportpersonal i tredjeland inte ska kunna ta del av personuppgifter eller känsliga personuppgifter i klartext, kommer det enligt vad regionen uppgett ändå kunna ske i supportärenden.

IMY kan inte, i enlighet med vad som framgår av EDPB:s rekommendationer, utifrån den senaste tekniska utvecklingen se att det i för närvarande finns några effektiva tekniska åtgärder som skulle förhindra att åtkomsten inkräktar på de registrerades grundläggande rättigheter i ett fall där personuppgifter behandlas i klartext i Indien eller

⁴¹ EDPB:s rekommendationer 01/2020, s. 18, punkt 46.

USA vid drift och support där sektion 702 i FISA, eller liknande lagstiftning som bedöms gå utöver vad som är nödvändigt och proportionerligt i ett demokratiskt samhälle, är tillämplig på överföringen och/eller personuppgiftsbiträdena i USA och Indien.

Det finns även vid behandling av personuppgifter som inte sker i klartext vid drift och support flera omständigheter som IMY bedömer manar till särskild försiktighet:

- behandlingens art – det rör sig om behandling av känsliga personuppgifter inom hälso- och sjukvården som är av mycket integritetskänsligt slag,
- behandlingens omfattning – personuppgiftsbehandlingen kan komma att omfatta alla invånare i regionens geografiska område, vilket enligt regionen uppskattar till cirka 1,4 miljoner registrerade personer,
- antalet drift- och supportärenden där personuppgifter kan komma att behandlas är omfattande (cirka 390 ärenden i månaden till Indien eller USA enligt regionens uppgifter) och
- att det är svårt att på förhand veta vilka ärenden och vilka personuppgifter supportpersonalen kan komma att ta del av.

IMY vill även, i enlighet med vad EDPB angett i sina rekommendationer, särskilt påtala att i situationer där okrypterade personuppgifter är nödvändiga för att genomföra tjänsten av personuppgiftsbiträdet, kryptering vid transport och data i vila-kryptering, även om dessa åtgärder vidtas tillsammans, inte är att anse som kompletterande skyddsåtgärder som säkerställer en väsentligt likvärdig skyddsnivå om aktören som mottar personuppgifter har krypteringsnyckeln. Detta innebär att, för det fall att ett personuppgiftsbiträde som mottar personuppgifterna också erhåller krypteringsnycklar, säkerställs inte en väsentligt likvärdig skyddsnivå genom den hanteringen.

Avslutande medskick

Avslutningsvis vill IMY ge några ytterligare medskick till regionen.

Riskbedömning av personuppgiftsbiträdet Cerner Sverige AB

Enligt artikel 28 i dataskyddsförordningen ska den personuppgiftsansvarige endast anlita personuppgiftsbiträden som ger tillräckliga garantier om att genomföra lämpliga tekniska och organisatoriska åtgärder på ett sådant sätt att behandlingen uppfyller kraven i dataskyddsförordningen och säkerställer att den registrerades rättigheter skyddas. Av samma artikel följer även att det i personuppgiftsbiträdesavtalet ska föreskrivas att personuppgiftsbiträdet endast får behandla personuppgifter på dokumenterade instruktioner från den personuppgiftsansvarige, inbegripet när det gäller överföringar av personuppgifter till ett tredjeland.

Ett medskick är att regionen bör överväga att göra en riskbedömning av Cerner Sverige AB i egenskap av personuppgiftsbiträde enligt artikel 28.1 i dataskyddsförordningen.⁴²

Om regionen inte i enlighet med artikel 28 kan få tillräckliga garantier från ett avsett personuppgiftsbiträde, kan regionen inte anlita det personuppgiftsbiträdet.

⁴² EDPB "Guidelines 07/2020 on the concepts of controller and processor in the GDPR", version 1.0, antagna den 2 september 2020, s. 30 p. 92, 94-95 och s. 34 p. 117.

Vidare åligger det också personuppgiftsbiträden att följa dataskyddsförordningen vid utförandet av sitt uppdrag, såsom att vidta lämpliga säkerhetsåtgärder för personuppgiftsbehandlingen enligt artikel 32 i dataskyddsförordningen.⁴³

Konsekvensbedömning

För det fall regionen inte gjort konsekvensbedömningar enligt artikel 35 i dataskyddsförordningen för personuppgiftsbehandling i det nya journalsystemet Millennium eller plattformen Healthelntent, bör regionen överväga att det görs. Se IMY:s förteckning, DI-2018-13200, över högriskbehandlingar där en konsekvensbedömning behöver göras och särskilt punkten "Teknik" där det framgår att konsekvensbedömningar ska göras för verksamheter som gör stora ändringar i sin tekniska infrastruktur och som behandlar personuppgifter inom exempelvis hälso- och sjukvård eller social omsorg (kriterium 4, 7 och 8 i förteckningen). Förteckningen finns tillgänglig på IMY:s webbplats⁴⁴.

Lights On Network

IMY har noterat att det i advokatfirmornas promemorior skrivits om en amerikansk molntjänst vid namn "Lights On Network" som synes tillhandahållas av Cerner för bolagets kunder. Verktuget beskrivs som att det är till för att mäta och förbättra vårdsystemets stabilitet och för att undersöka användarbeteende och baserat på faktiskt användande coacha användare till att arbeta mer effektivt. De personuppgifter som är tänkta att överföras är användares personuppgifter, dvs. regionens anställdas personuppgifter.

Om regionen avser att använda "Lights On Network" bör regionen utreda om behandlingen uppfyller de grundläggande principerna i artikel 5 i dataskyddsförordningen, vilken rättslig grund regionen stödjer behandlingen på enligt artikel 6 i dataskyddsförordningen och nationell rätt och om det finns förutsättningar att behandla känsliga personuppgifter enligt i artikel 9 i dataskyddsförordningen om det skulle bli aktuellt. Vidare bör regionen ta ställning till om det behöver göras en konsekvensbedömning enligt artikel 35 i dataskyddsförordningen avseende behandlingen.

Om det för denna behandling kan bli aktuellt med en överföring av personuppgifter till tredjeland bör regionen använda sig av EDPB:s rekommendationer 01/2020 och 02/2020 i det fortsatta arbetet.

Med detta svar avslutas ärendet.

Detta yttrande har beslutats av generaldirektören Lena Lindgren Schelin efter föredragning av juristen Linn Sandmark. I handläggningen har enhetschefen Malin Blixt och juristen Laura Eriksson medverkat. Vid den slutliga handläggningen har även rättschefen David Törngren, avdelningsdirektören Suzanne Isberg, juristen Petra Lennhede och it- och informationssäkerhetsspecialisten Adolf Slama medverkat.

Lena Lindgren Schelin, 2021-07-12 (Det här är en elektronisk signatur)

⁴³ Jfr IMY:s tillsynsbeslut DI-2019-2488.

⁴⁴ <https://www.imy.se/globalassets/block/verksamhet/dataskydd/forteckning---konsekvensbedomningar.pdf>